

Bayyina بيّنة

Third-Party / Vendor Risk Assessment

Automation for Government Contracts

Evidence-based vendor assurance for government contracts

Team VoidHack · Captain Piyush Goel

A government buyer decides which supplier to trust by reading a document the supplier wrote about itself. **Bayyina treats that document as a set of claims to be tested, not a form to be filed.** It checks every questionnaire answer that can be checked against evidence a buyer can gather without permission, and it refuses to rank bidders when the evidence cannot separate them.

48%

of breaches now involve a third party — 15% two years ago

Verizon DBIR 2026

\$8.45M

average cost of a supply-chain breach in the Middle East

IBM Cost of a Data Breach, August 2026

14%

of risk professionals believe vendor questionnaire answers —
84% rely on them anyway

Cyentia Institute / RiskRecon

RUN IT YOURSELF

github.com/pi-24/bayyina

```
git clone https://github.com/pi-24/bayyina.git && cd bayyina
pip install -e .
bayyina assess --tender scenarios/MDG-2026-114
```

Python, **no third-party dependencies**. Runs offline in about a second and passes 122 tests. Every figure in this deck is a screenshot of that command's output.

THAT COMMAND, ON THE DEMONSTRATION TENDER

BIDDER	POINT	RANGE	COVER	CONTRA	RELIABILITY
nawras	97.8	98–98	100%	0/15	100% (74–100%)
orion	58.5	32–76	57%	3/6	75% (30–95%)
meridian	31.8	31–35	96%	10/16	27% (10–57%)
Ranking					
Tier 1: nawras					
Tier 2: orion, meridian (not separable on available evidence)					

Meridian submitted the strongest paperwork of the three and finishes last, because ten of its sixteen checkable claims are contradicted by evidence. Orion is not ranked at all — too little of it is observable to place it honestly.

Project objective

The problem

Security due diligence in public procurement is a document exchange. The buyer sends a questionnaire, the supplier answers it about itself, an evaluator files it. Nothing in that loop tests whether any answer is true, so the supplier that writes the best document wins.

Meanwhile the supplier has become the way in. Third-party involvement in breaches went **15% → 30% → 48%** across three consecutive Verizon reports, and government suppliers are breached that way at roughly twice the global rate.

Why the current control fails

84% of buyers use security questionnaires

81% say vendors claim near-perfect compliance

14% believe the answers are accurate

Near-universal use, near-universal passing, near-zero belief. The Cloud Security Alliance — the body that writes the standard questionnaire — publishes the same criticism itself.

What UAE law already asks for

Federal Law No. 11 of 2023 on federal procurement:

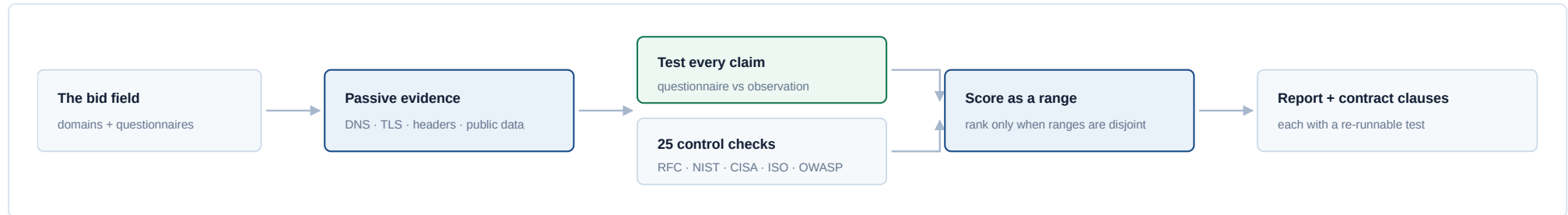
- **Art. 22(3)** — non-financial evaluation criteria must be “objective ... and quantifiable as much as possible.” A questionnaire yes/no is neither.
- **Art. 29** — a losing bidder may demand the “weaknesses and strengths” of its bid, so every finding has to keep the raw observation behind it.

Who runs it. The technical evaluator on a tender panel, inside the buyer's own environment. No subscription, no per-vendor fee, no data leaves.

AGAINST THE TWO THINGS A BUYER USES TODAY

	QUESTIONNAIRE	COMMERCIAL RATING	BAYYINA
Tests whether the supplier's answers are true	No — it <i>is</i> the answer	No — never sees it	Yes
Says what it could <i>not</i> observe	No	No — gaps vanish into the grade	Yes
Compares bidders against <i>each other</i>	No	No — one company at a time	Yes
Sees active compromise (botnet, C2 traffic)	No	Yes	No — I have no sensor network
Cost to assess three bidders on one contract	5–15 analyst hours each	\$12–25k a year to start	Free, self-hosted

Proposed solution



1. Mark the homework

Each questionnaire answer carries a machine-testable predicate. A bidder that answered “we enforce DMARC” has made a claim one DNS lookup can refute. **A contradiction counts for more than the flaw behind it:** a missing DMARC record is a config gap, but claiming it while publishing nothing is a false statement in a document the bidder signed — and evidence about every answer nobody can check.

2. Put a number on the part you cannot check

Most of a questionnaire is invisible from outside — background screening, key management, backup testing. But the checkable answers are a **sample**, and how they fare measures how far to trust the rest. Reported as a confidence interval over *independent evidence sources*, because three answers tested against a single web request are not three independent trials.

3. Refuse to rank on noise

Every score is a range: the bottom assumes everything unobserved was broken, the top assumes it was fine. **One bidder outranks another only when its worst case beats the other's best case.** Otherwise the tool says they cannot be separated and lists exactly what would settle it. Nothing is guessed at, so there is no hidden assumption to attack.

4. Look at the whole competition

Split an award between two suppliers for resilience and you may have bought two invoices and one failure domain. Bayyina compares upstream dependencies *across bidders* — DNS, mail, CDN, certificate authority. No commercial rating service sees this, because each one rates a single company in isolation.

It ends in contract language. Each finding becomes a drafted clause with a deadline and a named acceptance test: re-running the check that produced it. · **Passive only.** DNS lookups, one TLS handshake, one page fetch, public datasets. No port scanning, no probing, nothing needing a bidder's permission — which is what lets a buyer run this across a whole bid field before the tender even closes.

Solution validation

RUN IT TWICE, GET THE SAME ANSWER

```
$ bayyina reproduce
run 1: ledger 142e94cca9a8... result 08e678bb...
run 2: ledger 142e94cca9a8... result 08e678bb...

Identical.
```

Timestamps come from the evidence rather than the clock, so a replay next year gives today's answer. Evidence is recorded once and replayed offline, and the analysis code is the same either way — nothing is stubbed for the demo.

122 TESTS, 0.3 SECONDS

They cover the scoring rules, deliberately hostile input — null bytes, huge strings, injection attempts — and a suite dedicated to **gaming the tool**. That last one exists because an early version rewarded a bidder for submitting a corrupt questionnaire. It no longer does.

EVIDENCE YOU CANNOT QUIETLY EDIT

Every observation goes into a hash chain. Here is one stored DMARC record altered to look compliant:

```
Chain does NOT verify.
! record 6: payload does not match
its hash — the stored evidence was
modified after it was recorded
```

SAID PLAINLY

That is tamper-**evidence**, not tamper-proofing. Anyone holding the file could rewrite the whole chain. It catches silent edits to a stored assessment, which is the realistic procurement risk; stopping a malicious operator would need a signature from someone who does not control the file.

IS THE METHOD SOUND?

No machine learning, on purpose. There is no honest training set: a model fitted to public breach reports learns which companies *get reported*, not which are insecure. Published work predicts disclosed breaches from company size and sector alone, with no security data at all. Nothing here is fitted, so there is no train/test split and no leakage.

The weights belong to the buyer, and they are not load-bearing. They sit in the tender file because the law requires them published in advance, and re-ranking under 2,000 perturbed weightings leaves the winner unchanged every time.

WHAT IT CANNOT DO

No sensor network, so no view of active compromise. ISO 27001 scope adequacy cannot be automated and goes to a named human. SOC 2 cannot be verified at all — a private report with no registry. Breach history only counts *disclosed* breaches, so a clean record is weak evidence. All of it is printed in the output rather than hidden.

EVERY CHECK CITES THE STANDARD IT COMES FROM, AND THE TESTS PROVE IT RUNS

```
$ bayyina checks --check DNS-002
DNS-002 DMARC is published at an enforcing policy
category Technical hygiene
weight 3.0 (within category)
severity HIGH
authority
  · RFC 7489
  · CISA BOD 18-01 (p=reject mandated for US federal agencies)
```

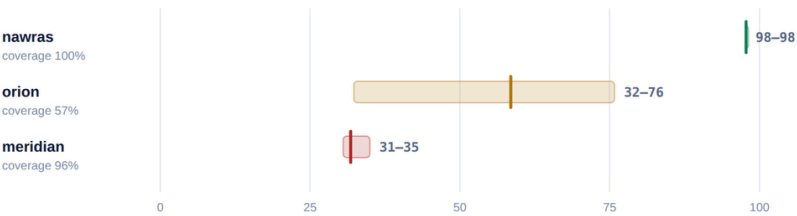
```
$ python -m pytest -q
..... [100%]
122 passed in 0.53s
```

No check is a number I invented. Each one names the RFC, NIST publication, CISA directive or OWASP guidance it enforces, so a bidder disputing a finding can argue with the standard rather than with me.

Results and conclusions

THREE BIDDERS, ONE CONTRACT

Meridian has the best paperwork — ISO 27001, SOC 2, a near-perfect questionnaire. **Nawras** has less. **Orion** is barely visible from outside.



The bar is the range the evidence supports. Where two bars overlap, the tool will not rank those bidders.

The paper favourite loses

10 of Meridian's 16 checkable claims are contradicted by evidence. It claims an enforcing DMARC policy and publishes one that blocks nothing. It claims no admin service is internet-facing; Remote Desktop and an open Elasticsearch say otherwise. Its ISO 27001 certificate covers *"the Dubai office"* — not the entity that would build the system.

Estimated reliability of its 20 untestable answers: **27%**, reported with the interval that says how little that is worth.

EVERY FINDING LEAVES AS A CONTRACT CLAUSE

One of Meridian's ten conditions precedent, as emitted:

```
CP-Q001 HIGH · CAIQ v4 IVS-09
Prior to award, the Supplier shall remediate the deficiency or submit
a corrected response to CAIQ v4 IVS-09 ...
Attested:   Deprecated TLS versions are disabled = True
Observed:   TLSv1, TLSv1.1 accepted on meridiangov.example
Verification: re-execution of predicate no_legacy_tls
```

CONTROL	CLAIM	OBSERVED	SEVERITY
CAIQ v4 IVS-09	Are deprecated TLS versions (1.0 and 1.1) disabled on all Internet-facing services? Attested: Deprecated TLS versions are disabled = True	TLSv1, TLSv1.1 accepted on meridiangov.example	HIGH
CAIQ v4 SEF-08	Is DMARC published and set to an enforcing policy (quarantine or reject) on your corporate domain? Attested: DMARC is published at an enforcing policy = True	DMARC published at p=none — monitoring only, blocks nothing	HIGH
CAIQ v4 SEF-09	Is SPF published with a hard-fail terminator on your corporate domain? Attested: SPF is published and enforcing = True	SPF exceeds the RFC 7208 10-lookup limit (11); receivers ignore it	MEDIUM

Nawras wins

Zero contradictions in 15 claims, full evidence coverage, and it stays ahead under every weighting tried.

Orion is not ranked

Only 57% of checks were observable, so the tool declines to place it and issues 12 document requests instead.

One failure domain

Meridian and Orion share DNS, CDN and mail. Splitting the award between them buys no resilience.

WHAT CHANGES FOR THE BUYER

- An award that can be defended line by line, with the raw observation behind every finding.
- **13 conditions precedent and 36 drafted contract clauses**, each with a deadline and a test that re-runs automatically.
- The split-award plan changes, because two of the three bidders are not independent.

Honesty note. The three bidders are invented and their domains are reserved test names; the evidence was generated by a script in the repository, and the scenario is built to show three different outcomes, so the contrast is sharper than a real tender would be. The same code runs live against real infrastructure, and sources for every figure are in the repo.